

Penetration Testing Methodology

Comprehensive End-to-End Execution & Testing Standard Guide

STANDARD ALIGNMENT	DOCUMENT PURPOSE	CLASSIFICATION
PTES, OWASP, NIST SP 800-115	Technical & Process Reference	Security Architecture / Operations

METHODOLOGY FRAMEWORK OVERVIEW

A structured penetration testing lifecycle simulates real-world attack vectors in a controlled, legal, and systematic manner. The goal is to proactively identify, validate, and remediate technical vulnerabilities before malicious threat actors can exploit them.



PHASE 01

Reconnaissance & Information Gathering

Building Target Footprint

Reconnaissance is the initial phase where security assessors collect as much public and technical intelligence about the target organization as possible without alerting defenders.

1. PASSIVE RECONNAISSANCE (NON-INTRUSIVE)

- Domain & WHOIS Analysis:** Query public domain registries to identify ownership details, contact emails, name servers, and IP allocations (`whois` , `RDAP`).
- DNS Infrastructure Mapping:** Extract record types (A, AAAA, MX, NS, TXT) and search historical DNS records using passive sources (`dig` , `SecurityTrails`, `VirusTotal`).
- Subdomain Enumeration:** Aggregating subdomains from public certificate logs (CT logs) and search engines (`Amass` , `Subfinder` , `crt.sh`).
- OSINT & Credential Leak Check:** Discover leaked employee credentials, code repositories, public cloud buckets, and organizational tech stacks (`Shodan` , `GitHub Search` , `theHarvester`).

2. ACTIVE RECONNAISSANCE (DIRECT INTERACTION)

- DNS Zone Transfers:** Test DNS servers for misconfigurations that allow complete zone dumping (`dig axfr`).
- Web Directory & Endpoint Crawling:** Map application endpoints, API routes, and hidden assets (`ffuf` , `Gobuster` , `Katana`).

Key Activity	Industry Tools	Primary Output Deliverable
Passive Intelligence Gathering	Amass, Shodan, Maltego, crt.sh	Domain/Subdomain inventory, IP ranges
OSINT Credential Discovery	theHarvester, Dehashed, GitLeaks	Exposed credentials, employee email list

Scanning transforms high-level target footprints into actionable technical endpoints by discovering open ports, listening services, operating systems, and software vulnerabilities.

1. NETWORK DISCOVERY & PORT SCANNING

- **Host Discovery:** Perform ICMP, TCP SYN, and UDP probes to discover live hosts across target IP blocks (`nmap -sn`).
- **Port Enumeration:** Scan all 65,535 TCP and top UDP ports to uncover open communication endpoints (`nmap -p- -sS` , `Masscan`).

2. SERVICE FINGERPRINTING & BANNER GRABBING

- **Version Detection:** Probe listening ports to extract service banners and exact software version strings (`nmap -sV`).
- **OS Fingerprinting:** Analyze TCP/IP stack behavior to identify underlying operating systems (`nmap -O`).

3. VULNERABILITY ASSESSMENT & RESOURCE ENUMERATION

- **Automated Vulnerability Scanning:** Run automated engines to query assets against CVE databases (`Nessus` , `OpenVAS` , `Qualys`).
- **Protocol-Specific Enumeration:** Query protocols directly (SMB shares, Active Directory LDAP objects, SNMP community strings, NFS mounts) to uncover misconfigurations.

Scanning Vector	Standard Tooling	Expected Findings
Network & Port Discovery	Nmap, Masscan, RustScan	Open TCP/UDP ports, listening services
Vulnerability Identification	Nessus, Nikto, OpenVAS, Nuclei	Unpatched software, misconfigurations, CVEs

The exploitation phase safely proves the impact of identified security flaws by gaining initial non-privileged or administrative access to the target systems.

1. VULNERABILITY VALIDATION

- **Manual Analysis:** Verify scanner findings manually to eliminate false positives prior to launching exploit payloads.
- **Exploit Research & Selection:** Search public databases (`Exploit-DB` , `Metasploit` , `GitHub` POCs) or craft tailored payloads targeting verified versions.

2. COMMON ATTACK VECTORS

- **Web Application Exploitation:** Execute vulnerabilities such as SQL Injection (SQLi), Cross-Site Scripting (XSS), Remote Code Execution (RCE), Server-Side Request Forgery (SSRF), and Insecure Direct Object References (IDOR).
- **Network & Infrastructure Exploitation:** Exploit unpatched service flaws (e.g., EternalBlue, Log4Shell, default administrative passwords, unauthenticated management portals).
- **Evasion & Bypass:** Apply payload obfuscation and encoding to bypass Web Application Firewalls (WAF) and Endpoint Detection & Response (EDR) systems responsibly.

Exploit Category	Primary Mechanisms	Impact Verification
Web Application Attack	SQLi, Command Injection, SSRF	Unauthorized data access, initial shell access
Service Vulnerability	Unpatched Buffer Overflow, RCE	System shell, service disruption proof

Post-exploitation assesses the potential scope of an actual breach by evaluating what an attacker could achieve after compromising an initial machine.

1. PRIVILEGE ESCALATION

- **Local System Escalation:** Elevate access from low-privilege user accounts to `root` or `SYSTEM` using OS misconfigurations, misconfigured `sudo` rights, unquoted service paths, or kernel exploits.
- **Active Directory Escalation:** Extract memory credentials (`Mimikatz`), execute Kerberoasting, or exploit Active Directory domain trust relationships.

2. PIVOTING & LATERAL MOVEMENT

- **Network Pivoting:** Route traffic through compromised hosts using SSH tunnels, SOCKS proxies, or tools like `chisel` to reach internal, non-routable network segments.
- **Domain Enumeration:** Map domain relationships, high-value targets, and administrative accounts using tools like `BloodHound` .

3. CLEANUP & RESTORATION

- **Artifact Removal:** Systematically delete temporary files, custom user accounts, injected binaries, and restore system configurations to their exact pre-assessment state.

The reporting phase translates complex technical findings into strategic business insights and actionable remediation guidelines for executive and technical teams.

1. TECHNICAL REPORT DELIVERABLES

- **Executive Summary:** High-level overview detailing overall organizational risk, key critical findings, business impact, and CVSS severity distribution for executive leadership.
- **Detailed Findings Narrative:** For each vulnerability, provide:
 - CVSS v3.1/v4.0 score and severity categorization (Critical, High, Medium, Low).
 - Affected hostnames, IP addresses, or URL endpoints.
 - Step-by-step Proof of Concept (PoC) instructions and reproduction steps.
 - Specific root cause analysis and technical mitigation recommendations.

2. REMEDIATION VERIFICATION (RE-TESTING)

- Validate patch implementations and configuration changes through structured re-scans and targeted manual testing to confirm complete risk mitigation.

MANDATORY GOVERNANCE: RULES OF ENGAGEMENT (ROE)

All penetration testing activities must strictly operate within pre-defined legal parameters:

- **Written Authorization:** Explicit legal consent signed by authorized system owners prior to execution.
- **Scope Boundaries:** Defined IP ranges, URLs, out-of-scope assets, and restricted testing windows.
- **Communication Channels:** Designated emergency contacts for immediate reporting of critical findings or unexpected outages.